

الوحدة 09: هجمات التطبيقات (Application Attacks)

Buffer Overflow (تجاوز سعة المخزن المؤقت)

يحدث عندما يكتب البرنامج بيانات أكثر من المساحة المخصصة في الذاكرة (Buffer)، مما يؤدي إلى تجاوز البيانات إلى مناطق ذاكرة مجاورة. يمكن للمهاجم استغلال ذلك لتنفيذ كود خبيث أو تعطيل البرنامج.

الوقاية: استخدام لغات آمنة مثل Rust، تفعيل ASLR و DEP، التحقق من حدود المدخلات (Input Validation).

مثال: فحص ASLR في Linux

```
cat /proc/sys/kernel/randomize_va_space
```

الشرح: يعرض قيمة ASLR (Address Space Layout Randomization). القيم المحتملة:

0 = معطل 1 = عشوائي (2 = Randomize = عشوائي كامل (مستحسن).

ASLR يجعل من الصعب على المهاجم توقع عناوين الذاكرة لتنفيذ هجوم Buffer Overflow.

Race Condition / TOCTOU (سباق التوقيت)

Race Condition: يحدث عندما تعتمد نتيجة عملية ما على توقيت تنفيذ خيوط متعددة (Threads).

TOCTOU (Time-of-Check Time-of-Use): نوع من Race Condition حيث يتغير مورد بين وقت التحقق منه ووقت استخدامه.

مثال: يتحقق البرنامج من صلاحية ملف ثم يستخدمه، لكن المهاجم يستبدل الملف في اللحظة بين الفحص والاستخدام.

SQL Injection (حقن SQL)

هجوم يقوم فيه المهاجم بإدخال استعلامات SQL ضارة في حقول الإدخال (مثل نموذج تسجيل الدخول) لاستخراج أو تعديل بيانات قاعدة البيانات.

مثال: إدخال ' OR '1'='1 في حقل كلمة المرور لتجاوز المصادقة.

الوقاية: استخدام Prepared Statements/Parameterized Queries، التحقق من المدخلات (Input Validation).

XSS / CSRF

XSS (Cross-Site Scripting): حقن سكريبت JavaScript ضار في صفحة ويب، ينفذ عندما يزور ضحية الصفحة. أنواعه: Reflected، DOM-based، Stored.

CSRF (Cross-Site Request Forgery): إجبار المستخدم على تنفيذ إجراء غير مرغوب فيه (مثل تغيير كلمة المرور) في موقع موثوق به دون علمه.

الوقاية: XSS: إفلات المخرجات (Output Encoding)، سياسة CSP (Content Security Policy).

CSRF: استخدام Anti-CSRF Tokens، التحقق من SameSite cookies.

مثال: اختبار XSS باستخدام curl

```
curl "http://example.com/search?q=<script>alert('XSS')</script>"
```

الشرح جزءاً جزءاً:

curl أداة سطر أوامر لإرسال طلبات HTTP.

المعامل q يمثل حقل البحث في موقع الويب.

<script>alert('XSS')</script> هو كود JavaScript يتم حقه.

إذا عادت الصفحة بنفس السكريبت دون تنقية (Sanitization)، فالموقع عرضة لهجوم XSS.

ملاحظة: استخدم هذا فقط على مواقعك الخاصة أو مواقع اختبار الاختراق المصرح بها.

(Quick Quiz (MCQ

1. Which attack involves writing data beyond the allocated buffer ?

- a) SQL Injection
- b) Buffer Overflow
- c) XSS
- d) CSRF

Answer: b

2. Which mitigation technique randomizes memory addresses on Linux ?

- a) DEP
- b) ASLR
- c) IDS
- d) HIPS

Answer: b

3. Which vulnerability exploits the time gap between check and use of a resource ?

- a) Buffer Overflow
- (b) TOCTOU (Race Condition
- c) XSS
- d) SQL Injection

Answer: b

4. What is the best defense against SQL Injection ?

- a) Input validation only
- (b) Prepared Statements (Parameterized Queries
- c) Longer passwords

d) Firewalls

Answer: b

?Which type of XSS injects code that executes in the victim's browser .5

a) SQL

b) JavaScript

c) HTML only

d) CSS

Answer: b